Unité 1 — Introduction à la sécurité logicielle

Livrable B — Support de cours · UE « Software Security »

Code UE 7532 14 U32 D1 · 11 octobre 2026

> **Place dans le programme.** Unité d'ouverture : elle pose le vocabulaire, les objectifs de sécurité et les principes qui structurent toute l'UE, et répond au point « identifier menaces, risques et vecteurs d'attaque ». *(introduction, CIAAA, « why security is hard », OWASP, incidents célèbres).*

1. Qu'est-ce que la sécurité logicielle ?

La **fiabilité** vise un bon fonctionnement face à des entrées *normales* ; la **sécurité** vise un bon fonctionnement face à un **adversaire** qui cherche activement des entrées *anormales*. Un logiciel peut être fiable et non sûr : c'est la présence d'un attaquant intelligent qui change tout.

2. Les objectifs de sécurité : CIA → CIAAA

Propriété	Définition
Confidentialité	seules les personnes autorisées accèdent à l'information.
Intégrité	l'information n'est pas altérée de façon non autorisée.
Disponibilité	le service reste accessible quand il le faut.
Authenticité	l'origine/identité est vérifiable.
Auditabilité	les actions sont traçables (journaux).

3. Pourquoi la sécurité est difficile

- **Asymétrie** : le défenseur doit tout protéger, l'attaquant n'a besoin que d'une faille.
- **Composition** : des composants sûrs isolément peuvent être non sûrs ensemble.
- **Entrées adverses** : l'attaquant choisit les pires entrées (cf. Unités 2, 7).
- **Mauvais défauts** : réglages par défaut non sûrs, API dangereuses.
- **Code ancien** : des millions de lignes de C/C++ héritées.

4. Vocabulaire

Terme	Définition
Actif	ce qui a de la valeur (données, service).
Vulnérabilité	faiblesse exploitable (cf. CWE, Unité 10).
Menace	acteur/événement susceptible d'exploiter une vulnérabilité.
Attaque / vecteur	mise en œuvre concrète / voie empruntée.
Risque	gravité × probabilité (cf. CVSS, Unité 10).
Surface d'attaque	ensemble des points d'entrée exposés.

5. Principes de conception sécurisée

- **Moindre privilège** : donner le minimum de droits nécessaire.
- **Défense en profondeur** : plusieurs barrières indépendantes (cf. Unité 4).
- **Fail-safe** : en cas d'erreur, refuser par défaut.
- **Séparation des privilèges** et **médiation complète** (vérifier chaque accès).
- **Simplicité** (économie de mécanisme) et **défauts sûrs**.

6. Panorama des menaces applicatives — OWASP Top 10

L'**OWASP Top 10** recense les risques web les plus courants : contrôle d'accès défaillant, défaillances cryptographiques, **injection** (Unités 7–8), conception non sécurisée, mauvaise configuration, composants vulnérables, etc. Il sert de référentiel partagé pour prioriser.

7. Catégories de code malveillant

Virus, vers (propagation autonome : cf. Morris), chevaux de Troie, rançongiciels, portes dérobées, logiciels espions : souvent *livrés* via une vulnérabilité applicative étudiée dans l'UE.

8. Quelques incidents fondateurs

Incident	Leçon / lien UE
Morris Worm (1988)	débordement de tampon exploité à grande échelle → Unités 2, 4.
Heartbleed (2014)	un contrôle de borne manquant expose la mémoire → Unité 3.
Equifax (2017)	composant web non corrigé (injection) → Unités 7–9.

9. Panorama du cours

Mémoire & pile (U2), tas & temporel (U3), défenses (U4), analyse & sanitizers (U5), langages sûrs (U6), injections (U7–U8), bonnes pratiques & SAST (U9), risque & CVSS (U10), fuzzing (U11), projet (U12).

10. Points clés

- Sécurité = fiabilité *en présence d'un adversaire*.
- Objectifs : CIAAA ; vocabulaire : actif/vuln/menace/risque/surface.
- Principes de conception : moindre privilège, défense en profondeur, fail-safe.

(intro, CIAAA, OWASP, incidents).